

TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN
BÁO CÁO TIỂU LUẬN CUỐI KỲ
HỌC PHẦN: BẢO MẬT IoT
TÊN ĐỀ TÀI

CẬP NHẬT FIRMWARE AN TOÀN CHO THIẾT BỊ IoT

Mã học phần	INT4410
Lớp học phần	253INT441001
Giảng viên hướng dẫn	ThS. Hồ Nhựt Minh
Sinh viên/Nhóm	Trần Thị Hà Vy – cá nhân
Thành viên - MSSV	Trần Thị Hà Vy - 231A010297
Link repo GitHub	https://github.com/hv6z/n20-secure-firmware-update-iot
Ngày nộp	25/07/2026

TP. HỒ CHÍ MINH, 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Cập nhật firmware an toàn cho thiết bị IoT
Mã đề tài	20
Sinh viên/Nhóm	Trần Thị Hà Vy - 231A010297
Repo GitHub	https://github.com/hv6z/n20-secure-firmware-update-iot
Bản báo cáo	231A010297_TrầnThịHàVy_DeTai20_TieuLuan_CuoiKy.docx
Sản phẩm chính	Code demo, manifest, policy, log, ma trận kiểm thử, sơ đồ OTA và bảng rủi ro
Ngày nộp	25/07/2026

Cam kết an toàn và học thuật

Tôi/chúng tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân/nhóm; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

- + Họ tên cam kết: Trần Thị Hà Vy
- + Ngày cam kết: 27/07/2026
- + Chữ ký:


Trần Thị Hà Vy

MỤC LỤC

THÔNG TIN VÀ CAM KẾT NỘP BÀI	2
Cam kết an toàn và học thuật.....	2
MỤC LỤC	3
DANH MỤC TỪ VIẾT TẮT	5
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI	6
1.1. Bối cảnh và lý do chọn đề tài	6
1.2. Vấn đề bảo mật và kịch bản tấn công	6
1.3. Mục tiêu đo được.....	6
1.4. Đối tượng, phạm vi và giới hạn an toàn	7
1.5. Sản phẩm và đóng góp	7
1.6. Cấu trúc báo cáo	7
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN.....	8
2.1. Kiến trúc và biên tin cậy của chuỗi cập nhật.....	8
2.2. Các khái niệm bảo mật được sử dụng.....	8
2.3. Chuỗi boot/update, phần cứng và bảo vệ khóa.....	9
2.4. Chuẩn, công cụ và repository tham chiếu.....	9
2.5. So sánh các giải pháp gần nhất.....	10
2.6. Tiểu kết Chương 2.....	10
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ	11
3.1. Phương pháp thực hiện.....	11
3.2. Mô hình đề xuất.....	11
3.3. Môi trường, công cụ và dữ liệu	12
3.4. Quy trình và mốc thực hiện	12
3.5. Tiêu chí đánh giá và ngưỡng PASS.....	13
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ.....	14
4.1. Chuẩn bị môi trường và chạy mô phỏng	14
4.2. Thành phần sản phẩm và cấu trúc repository	14
4.3. Kịch bản kiểm thử	15
4.4. Kết quả và đối chiếu tiêu chí	15
4.5. Script tổng hợp kết quả.....	16
4.6. Thảo luận và giới hạn	16
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT.....	17
5.1. Tài sản và yêu cầu CIA.....	17
5.2. Phân tích STRIDE gắn với hệ thống	17

5.3. Ma trận rủi ro 5×5 và ưu tiên.....	18
5.4. Kiểm soát theo rủi ro ưu tiên	18
5.5. Rủi ro còn lại và điều kiện xem xét lại	19
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	20
6.1. Kết luận theo mục tiêu.....	20
6.2. Hạn chế.....	20
6.3. Hướng phát triển.....	20
TÀI LIỆU THAM KHẢO	21
PHỤ LỤC A. PHẦN A – CHECKLIST VÀ PHIẾU TIẾN ĐỘ	22
A.1. Checklist nhanh trước khi viết – Tuần 02.....	22
A.2. Góp ý và cách xử lý – Tuần 02.....	22
A.3. Minh chứng đã khai báo – Tuần 02	23
A.4. Thông tin chung của phiếu tiến độ	24
A.5. Checklist tiến độ Tuần 02	25
A.6. Nội dung đã thực hiện trong tuần	26
A.7. Khó khăn/rủi ro đang gặp	27
A.8. Kế hoạch Tuần 03.....	27
A.9. Tự đánh giá của sinh viên.....	28
PHỤ LỤC B. REPOSITORY, COMMIT VÀ GÓI NỘP.....	29
PHỤ LỤC C. CHECKLIST TRƯỚC KHI IN VÀ NỘP.....	30
PHỤ LỤC D. CÂU HỎI CHUẨN BỊ BẢO VỆ.....	31

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1	OTA	Over-the-Air – cập nhật firmware qua mạng
2	IoT	Internet of Things – Internet vạn vật
3	AEAD	Authenticated Encryption with Associated Data – mã hóa có xác thực
4	AAD	Associated Authenticated Data – dữ liệu xác thực nhưng không mã hóa
5	RSA-PSS	Cơ chế chữ ký số dựa trên RSA
6	RSA-OAEP	Cơ chế bọc khóa dựa trên RSA
7	AES-GCM	Chế độ mã hóa xác thực Galois/Counter Mode
8	SHA-256	Hàm băm mật mã 256 bit
9	HSM	Hardware Security Module – mô-đun bảo vệ khóa
10	STRIDE	Mô hình phân loại sáu nhóm mối đe dọa

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Firmware điều khiển trực tiếp cảm biến, bộ chấp hành, bộ nhớ và giao tiếp mạng của thiết bị IoT. Khi có lỗi hỏng, cập nhật OTA giúp nhà sản xuất sửa lỗi mà không phải thu hồi thiết bị; ngược lại, một kênh cập nhật thiếu xác minh có thể trở thành đường nạp mã độc. Thiết bị IoT thường phân tán, hoạt động lâu năm và khó bảo trì trực tiếp, nên sai sót trong cơ chế cập nhật có thể tồn tại lâu và ảnh hưởng đồng thời đến nhiều thiết bị.

Đề tài 20 lựa chọn mô hình mô phỏng cục bộ để làm rõ nguyên tắc cốt lõi: máy chủ OTA chỉ là nơi phân phối, còn thiết bị phải tự xác minh gói trước khi ghi và kích hoạt. Mô hình sử dụng manifest, SHA-256, chữ ký RSA-PSS, mã hóa xác thực AES-256-GCM, ràng buộc target và sequence, vùng staging, self-test và rollback. Cách tiếp cận này phù hợp hướng C – firmware, thiết bị và an toàn vật lý.

1.2. Vấn đề bảo mật và kịch bản tấn công

Kịch bản chính là kẻ tấn công kiểm soát đường truyền hoặc kho phân phối, sau đó thay gói firmware bằng nội dung đã sửa, phát lại một phiên bản cũ còn lỗi hỏng hoặc gửi gói dành cho thiết bị khác. Nếu thiết bị chỉ kiểm tra tên phiên bản hay hash không được ký, kẻ tấn công có thể thay cả firmware và giá trị hash. Nếu thiết bị ghi trực tiếp lên phân vùng đang chạy, một bản cập nhật hợp lệ về mật mã nhưng lỗi chức năng cũng có thể làm thiết bị không khởi động.

Câu hỏi nghiên cứu là: dữ liệu nào cần bí mật, toàn vẹn và xác thực; cơ chế nào phải được kiểm tra trước khi ghi flash; trạng thái nào cần lưu để chống rollback; và bằng chứng nào đủ để người khác chạy lại, quan sát ACCEPT/REJECT và đối chiếu với tiêu chí đã đặt.

1.3. Mục tiêu đo được

ID	Mục tiêu đo được	Đầu ra	Cách kiểm chứng	Trình bày
MT-01	Nhận diện ≥ 5 rủi ro và biên tin cậy của chuỗi OTA.	STRIDE, risk register, ma trận 5×5 .	Có ID, K, T, điểm và kiểm soát.	Ch. 5
MT-02	Tạo gói có manifest, SHA-256, RSA-PSS và AES-256-GCM.	Code, policy, manifest và chữ ký mẫu.	Chạy demo; xem results/*.json.	Ch. 3–4
MT-03	Mô phỏng target, sequence, staging, self-test và rollback.	Quy trình OTA và trạng thái thiết bị.	TC-04 và TC-05 phải REJECT đúng lý do.	Ch. 3–4
MT-04	Tạo bộ minh chứng tái lập với 5 ca kiểm thử.	README, log, CSV, hình và commit.	5/5 ca trùng kỳ vọng; repo mở được.	Ch. 4

1.4. Đối tượng, phạm vi và giới hạn an toàn

Đối tượng nghiên cứu là chuỗi phát hành–phân phối–xác minh–kích hoạt firmware cho target giả lập `iot-demo-board-v1`. Dữ liệu gồm firmware nhị phân giả lập `v1`, `v2` và `v3_bad`; manifest JSON; khóa công khai demo; policy; log và ma trận kiểm thử. Mô phỏng chạy trên máy cá nhân bằng Python, không kết nối thiết bị thật và không gửi lưu lượng tới hệ thống bên ngoài.

Phạm vi chưa bao gồm bootloader thật, eFuse, Secure Boot, flash encryption, secure element/HSM, HTTPS/mTLS, cập nhật vi sai, mất điện giữa lúc ghi flash, side-channel hoặc benchmark CPU–RAM–năng lượng trên MCU. Các khóa của demo không phải khóa triển khai; repo không chứa token, mật khẩu hay dữ liệu cá nhân thật.

1.5. Sản phẩm và đóng góp

- + Mã mô phỏng `src/code_demo.py` và chính sách `configs/security_policy.json`.
- + Firmware mẫu, manifest, manifest đã ký, khóa công khai demo, log và ma trận 5 ca kiểm thử.
- + Sơ đồ luồng OTA, bảng STRIDE, ma trận rủi ro 5×5 và checklist kiểm soát.
- + Repository công khai <https://github.com/hv6z/n20-secure-firmware-update-iot>, mốc đối chiếu `a8febb243aca96388c1981e141e823b8f397af8b`.

1.6. Cấu trúc báo cáo

Chương 1 xác định vấn đề, mục tiêu và phạm vi. Chương 2 trình bày kiến trúc, cơ chế bảo mật và nguồn được sử dụng. Chương 3 mô tả phương pháp, mô hình, môi trường, quy trình và tiêu chí. Chương 4 trình bày triển khai, cách chạy và kết quả. Chương 5 đánh giá tài sản, STRIDE, rủi ro, kiểm soát và rủi ro còn lại. Chương 6 đối chiếu mục tiêu, nêu hạn chế và hướng phát triển. Các phiếu tiến độ và minh chứng repository được giữ ở phụ lục.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc và biên tin cậy của chuỗi cập nhật

Kiến trúc gồm ba vùng: (1) môi trường phát hành đáng tin cậy giữ khóa riêng và tạo gói; (2) máy chủ OTA/kênh truyền không được tin cậy tuyệt đối; (3) thiết bị giữ root of trust, khóa xác minh và trạng thái sequence. Manifest ký các trường schema, target, version, sequence, size, SHA-256 và thuật toán. Vì máy chủ phân phối có thể bị thay đổi, quyết định cuối cùng luôn do thiết bị đưa ra.



Hình 2.1. Kiến trúc và luồng dữ liệu cập nhật OTA; biên tin cậy nằm giữa môi trường phát hành, máy chủ phân phối và thiết bị. Nguồn: tác giả xây dựng.

Trong Hình 2.1, HTTPS/mTLS nếu được triển khai chỉ bảo vệ kênh. Chữ ký manifest vẫn cần thiết để bảo vệ đầu-cuối khi gói đi qua cache, CDN hoặc máy chủ trung gian. Thiết bị phải fail closed: bất kỳ lỗi cấu trúc, target, chữ ký, sequence, tag AEAD, kích thước hoặc hash nào đều dẫn đến REJECT trước khi commit.

2.2. Các khái niệm bảo mật được sử dụng

Khái niệm	Vai trò trong đề tài	Ví dụ trong mô hình
Xác thực nguồn gốc	Chứng minh manifest do bên giữ khóa ký phát hành.	RSA-PSS xác minh `signed_manifest_v2.json`.
Toàn vẹn	Phát hiện nội dung bị sửa.	Chữ ký manifest, AES-GCM tag và SHA-256 firmware.
Bí mật	Giảm lộ nội dung firmware khi phân phối.	Payload AES-256-GCM; khóa AES bọc RSA-OAEP.
Chống rollback	Không cho cài bản cũ dù chữ ký còn hợp lệ.	`sequence` mới phải lớn hơn trạng thái đã lưu.
Đúng target	Ngăn cài nhầm firmware cho model khác.	`target` đã ký phải bằng `iot-demo-board-v1`.
Khả dụng/phục hồi	Không commit bản không hoạt động.	Staging → self-test → commit; lỗi thì rollback.

2.3. Chuỗi boot/update, phần cứng và bảo vệ khóa

Trong prototype, khóa riêng nhà phát hành chỉ tồn tại trong lúc tạo gói; repo chỉ lưu khóa công khai demo. Khi triển khai thật, khóa ký nên ở HSM và có quy trình phân quyền, xoay vòng, thu hồi. Phía thiết bị, khóa công khai và bộ đếm chống rollback cần được neo vào vùng chống sửa như eFuse hoặc secure element; bootloader phải xác minh ảnh trước khi chuyển quyền điều khiển.

Điểm kiểm tra	Dữ liệu	Kiểm soát	Nếu thất bại
Trước tải/parse	Kích thước, schema	Giới hạn 4 MiB; trường bắt buộc	REJECT
Trước giải mã	Target, chữ ký, sequence	RSA-PSS; target đã ký; sequence tăng	REJECT
Sau giải mã	Tag, size, SHA-256	AES-GCM; đối chiếu metadata	REJECT
Sau ghi staging	Khả năng hoạt động	Self-test	Rollback
Khi boot	Ảnh đang kích hoạt	Secure Boot/boot verification (đề xuất)	Boot ảnh dự phòng

2.4. Chuẩn, công cụ và repository tham chiếu

STT	Nguồn	URL	Phân sử dụng	Truy cập
1	IETF RFC 9019	https://datatracker.ietf.org/doc/html/rfc9019	Kiến trúc cập nhật firmware IoT	25/07/2026
2	IETF RFC 9124	https://datatracker.ietf.org/doc/html/rfc9124	Manifest và điều kiện xử lý	25/07/2026
3	NIST SP 800-193	https://csrc.nist.gov/pubs/sp/800/193/final	Bảo vệ, phát hiện, phục hồi firmware	25/07/2026
4	RFC 8017	https://datatracker.ietf.org/doc/html/rfc8017	RSA-PSS và RSA-OAEP	25/07/2026
5	NIST SP 800-38D	https://csrc.nist.gov/pubs/sp/800/38/d/final	AES-GCM và yêu cầu	25/07/2026

STT	Nguồn	URL	Phân sử dụng	Truy cập
			IV/nonce	
6	ESP-IDF OTA	https://docs.espressif.com/projects/esp-idf/en/v5.4.2/esp32/api-reference/system/ota.html	Phân vùng OTA, rollback	25/07/2026
7	OWASP IoT ISVS	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Yêu cầu cập nhật và bảo vệ khóa	25/07/2026
8	Repo đề tài	https://github.com/hv6z/n20-secure-firmware-update-iot	Code, cấu hình, log và sản phẩm	25/07/2026

2.5. So sánh các giải pháp gần nhất

Giải pháp/nguồn	Mục tiêu & phương pháp	Ưu điểm	Giới hạn/kế thừa
IETF SUIT (RFC 9019/9124)	Kiến trúc và manifest cập nhật cho thiết bị hạn chế.	Tách vai trò; điều kiện rõ; hướng đầu-cuối.	Prototype kế thừa manifest và điều kiện; chưa mã hóa CBOR/COSE.
ESP-IDF OTA	Cập nhật qua phân vùng OTA, xác nhận ảnh và rollback.	Gần triển khai ESP32; có A/B và bootloader.	Báo cáo kế thừa staging/rollback; chưa chạy trên ESP32.
NIST SP 800-193	Khả năng phục hồi firmware: protect–detect–recover.	Nhấn mạnh phục hồi, root of trust.	Kế thừa self-test/rollback; chưa có phần cứng root of trust.

2.6. Tiểu kết Chương 2

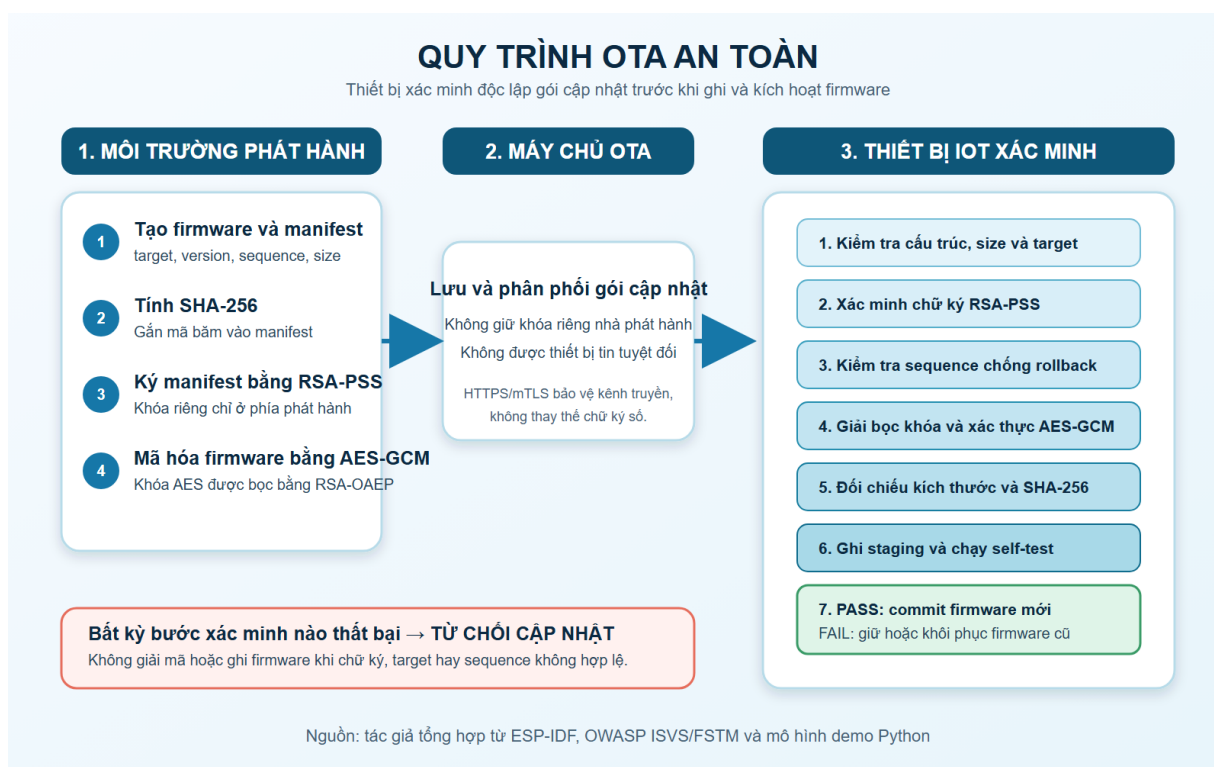
Cơ sở lý thuyết cho thấy một cập nhật an toàn không thể chỉ dựa vào mã hóa hoặc hash. Cần kết hợp xác thực nguồn, toàn vẹn, chống rollback, ràng buộc target và phục hồi. Chương 3 chuyển các yêu cầu này thành mô hình cục bộ, quy trình thực hiện và tiêu chí PASS có thể kiểm tra.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

1. Khảo sát yêu cầu: đọc RFC 9019/9124, NIST SP 800-193, tài liệu ESP-IDF và OWASP; đầu ra là danh sách tài sản, biên tin cậy và kiểm soát.
2. Thiết kế: xác định manifest, thuật toán, thứ tự xác minh và trạng thái thiết bị; đầu ra là policy, sơ đồ và bảng checkpoint.
3. Xây dựng lab cục bộ: tạo firmware giả lập, gói ký/mã hóa và thiết bị xác minh bằng Python; đầu ra là code và dữ liệu mẫu.
4. Kiểm thử theo mỗi đe dọa: tạo một ca hợp lệ và bốn ca lỗi/tấn công; đầu ra là log và CSV.
5. Đánh giá: so sánh actual với expected, lập STRIDE và ma trận 5×5; đầu ra là kết luận theo MT-01...MT-04.

3.2. Mô hình đề xuất



Hình 3.1. Mô hình cập nhật firmware an toàn do sinh viên đề xuất và số hóa từ bản phác thảo. Nguồn: tác giả xây dựng.

Thiết kế đặt các phép kiểm tra rẻ và không làm thay đổi trạng thái trước: cấu trúc, kích thước, target, chữ ký và sequence. Chỉ sau đó thiết bị mới giải bọc khóa, xác thực/giải mã payload, đối chiếu size và hash. Firmware được ghi vào staging, không ghi đè bản đang chạy; commit chỉ xảy ra sau self-test. Thứ tự này giảm nguy cơ tiêu tốn tài nguyên cho gói sai và tránh mất khả năng phục hồi.

3.3. Môi trường, công cụ và dữ liệu

Thành phần	Phiên bản/giá trị	Vai trò	Nguồn dữ liệu
Hệ điều hành	Windows, kiểm tra 25/07/2026	Môi trường chạy cục bộ	Máy cá nhân
Python	3.12.13 khi rà soát; README yêu cầu 3.11+	Chạy prototype và test	Python runtime
cryptography	Repo quy định $\geq 44, < 47$	RSA-PSS/OAEP, AES-GCM	requirements.txt
Target	iot-demo-board-v1	Ràng buộc đúng model	security_policy.json
Firmware	v1, v2, v3_bad	Hợp lệ, rollback, lỗi self-test	data/ – dữ liệu giả lập
Git/GitHub	main @ eda9be5	Quản lý và đối chiếu minh chứng	https://github.com/hv6z/n20-secure-firmware-update-iot

3.4. Quy trình và mốc thực hiện

Bước	Mốc/ngày	Công việc	Sản phẩm/minh chứng
1	14/07/2026	Khởi tạo repo, policy và firmware mẫu.	README, configs/, data/
2	16/07/2026	Hoàn thiện manifest, mã demo và sơ đồ.	src/, results/*.json, hình
3	18/07/2026	Chạy 5 ca, dọn khóa/file tạm, cập nhật báo cáo.	log, CSV, lịch sử commit
4	23/07/2026	Điền nội dung vào form tiểu luận.	Bản Word tích lũy
5	25/07/2026	Đối chiếu phiếu hướng dẫn, chạy lại 5 ca và hoàn thiện bản in.	5/5 PASS; DOCX/PDF cuối

3.5. Tiêu chí đánh giá và ngưỡng PASS

Tiêu chí	Ngưỡng PASS	Bằng chứng
Đúng quyết định	TC-01 ACCEPT; TC-02...TC-05 REJECT đúng lớp kiểm soát.	test_matrix.csv và log
Độ bao phủ tình huống	Có ≥ 5 ca: hợp lệ, sai chữ ký, sai ciphertext, rollback, self-test lỗi.	Bảng 4.2
Khả năng tái lập	Cài requirements và chạy một lệnh; kết thúc SUMMARY fail=0.	README và Hình 4.1
An toàn repository	Không có khóa riêng triển khai, token, mật khẩu hay file tạm.	.gitignore, README_KEYS, cây repo
Liên kết mục tiêu	MT-01...MT-04 đều có đầu ra và minh chứng.	Bảng 6.1

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường và chạy mô phỏng

Repository được lấy từ nhánh main tại commit nêu trong Chương 1. Môi trường rà soát dùng Windows và Python 3.12.13. Để tái lập theo cấu hình dự án, người dùng tạo môi trường ảo, cài `requirements.txt` và chạy `python src/code\_demo.py --demo`. Chương trình tự tạo gói, chạy năm kịch bản, ghi log và CSV.

```
python -m venv .venv
.venv\Scripts\activate
python -m pip install -r requirements.txt
python src\code_demo.py --demo
```

```
PowerShell - mô phỏng cập nhật firmware an toàn
PS> python src/code_demo.py --demo
Môi trường kiểm tra: Python 3.12.13 | Windows | 25/07/2026

CASE=valid_signed_update EXPECTED=ACCEPT ACTUAL=ACCEPT RESULT=PASS DETAIL=Đã cài phiên bản 2.0.0 (sequence 2)
CASE=tampered_manifest_signature EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS DETAIL=Chữ ký manifest không hợp lệ
CASE=tampered_ciphertext EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS DETAIL=Giải mã/xác thực AES-GCM thất bại
CASE=rollback_sequence EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS DETAIL=Chống rollback: sequence 1 <= 1
CASE=failed_self_test EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS DETAIL=Self-test thất bại; đã rollback về firmv
SUMMARY total=5 pass=5 fail=0
```

Hình 4.1. Kết quả chạy mô phỏng cục bộ ngày 25/07/2026; dữ liệu hiển thị được trích nguyên từ log do chương trình tạo.

4.2. Thành phần sản phẩm và cấu trúc repository

```
n20-secure-firmware-update-iot/
├─ configs/security_policy.json
├─ data/firmware_v1.bin, firmware_v2.bin, firmware_v3_bad.bin
├─ src/code_demo.py, src/README_KEYS.md
├─ results/manifest_v2.json, signed_manifest_v2.json
├─ results/logs/secure_update_demo.log, results/test_matrix.csv
├─ update_so_do_hinh_anh/ └─ report/
```

Thành phần	Chức năng	Minh chứng
security_policy.json	Cố định target, giới hạn 4 MiB, thuật toán và yêu cầu rollback.	configs/
code_demo.py	Đóng gói, ký, mã hóa, xác minh, staging, self-test và test runner.	src/
manifest/chữ ký	Mô tả và xác thực gói v2.	results/*.json
log/ma trận	Ghi actual, expected, PASS/FAIL và lý do.	results/logs/, test_matrix.csv
sơ đồ	Mô tả luồng khóa, dữ liệu và OTA.	update_so_do_hinh_anh/
báo cáo	Gói trình bày và nộp bài.	report/

4.3. Kịch bản kiểm thử

ID	Mô tả/đầu vào	Thao tác	Kỳ vọng	Kiểm soát
TC-01	Firmware v2 và manifest hợp lệ.	Chạy quy trình đầy đủ.	ACCEPT	Toàn chuỗi
TC-02	Sửa một trường manifest sau khi ký.	Xác minh RSA-PSS.	REJECT	Xác thực nguồn
TC-03	Lật byte ciphertext.	Xác thực AES-GCM.	REJECT	Toàn vẹn payload
TC-04	Gói v1 có sequence 1 khi current=1.	So sánh sequence.	REJECT	Chống rollback
TC-05	v3_bad có chữ ký hợp lệ nhưng self-test lỗi.	Ghi staging, chạy self-test.	REJECT + rollback	Phục hồi

4.4. Kết quả và đối chiếu tiêu chí

Ca	Kỳ vọng	Thực tế	Kết quả	Chi tiết log
TC-01	ACCEPT	ACCEPT	PASS	Đã cài 2.0.0 (sequence 2)
TC-02	REJECT	REJECT	PASS	Chữ ký manifest không hợp lệ
TC-03	REJECT	REJECT	PASS	Xác thực AES-GCM thất bại
TC-04	REJECT	REJECT	PASS	sequence 1 <= 1
TC-05	REJECT + rollback	REJECT + rollback	PASS	Self-test lỗi; khôi phục bản trước

Kết quả ngày 25/07/2026 là 5/5 PASS, đúng ngưỡng ở Mục 3.5. TC-02 cho thấy hash đơn lẻ không xác thực nhà phát hành; TC-03 chứng minh AEAD phát hiện payload bị sửa; TC-04 cho thấy chữ ký hợp lệ không đồng nghĩa gói là mới; TC-05 cho thấy xác thực

mật mã không thay thế kiểm thử khả năng hoạt động. Log đầy đủ được lưu tại `results/logs/secure\_update\_demo.log`.

4.5. Script tổng hợp kết quả

`src/code\_demo.py` vừa là prototype vừa là script báo cáo. Đầu vào là policy và firmware giả lập; đầu ra là manifest, chữ ký, khóa công khai demo, log và `test\_matrix.csv`. Hàm test runner trả mã thoát khác 0 nếu có ca FAIL, nhờ đó có thể đưa vào CI sau này. Trích xuất 6 dòng cuối của lần chạy:

```
CASE=valid_signed_update EXPECTED=ACCEPT ACTUAL=ACCEPT
RESULT=PASS
CASE=tampered_manifest_signature EXPECTED=REJECT ACTUAL=REJECT
RESULT=PASS
CASE=tampered_ciphertext EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
CASE=rollback_sequence EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
CASE=failed_self_test EXPECTED=REJECT ACTUAL=REJECT RESULT=PASS
SUMMARY total=5 pass=5 fail=0
```

4.6. Thảo luận và giới hạn

4.6.1. Đối chiếu mục tiêu. MT-02, MT-03 và MT-04 được chứng minh trực tiếp bằng code, policy, năm ca kiểm thử, log và CSV. MT-01 được hoàn thiện trong Chương 5. Mô hình đạt yêu cầu học phần vì có thể chạy lại, có cả ca thành công và thất bại, và giải thích được mỗi quyết định.

4.6.2. Giới hạn mô phỏng. Kết quả chỉ xác nhận logic prototype trên máy tính, không phải chứng nhận an toàn sản xuất. Báo cáo không tuyên bố đã chạy Wokwi hay ESP32 thật. Chưa đo độ trễ, RAM, năng lượng; chưa kiểm thử mất điện, lỗi flash, parser fuzzing hoặc tấn công side-channel. Các khoảng trống này được giữ rõ để tránh suy rộng vượt quá bằng chứng.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT**5.1. Tài sản và yêu cầu CIA**

Tài sản	Giá trị/chủ thể	C	I	A	Kiểm soát chính
Khóa riêng ký	Quyền phát hành / publisher	Rất cao	Rất cao	Cao	HSM, phân quyền, rotate/revoke
Khóa công khai gốc	Root of trust / thiết bị	Thấp	Rất cao	Cao	eFuse/secure element
Firmware	Mã thực thi / thiết bị	Cao	Rất cao	Rất cao	AES-GCM, SHA-256, ký manifest
Manifest	Quy tắc cài đặt	Thấp	Rất cao	Cao	RSA-PSS
Sequence/trạng thái	Chống rollback	Thấp	Rất cao	Cao	Lưu bền vững, cập nhật nguyên tử
Bản đang chạy	Khả năng vận hành	Tùy loại	Cao	Rất cao	A/B, self-test, rollback

5.2. Phân tích STRIDE gắn với hệ thống

STRIDE	Mối đe dọa trong chuỗi OTA	Tài sản	Kiểm soát/minh chứng
S – Spoofing	Giả mạo nhà phát hành.	Firmware, manifest	RSA-PSS; TC-02
T – Tampering	Sửa manifest hoặc ciphertext.	Manifest, payload	Chữ ký, AES-GCM, SHA-256; TC-02/03
R – Repudiation	Phủ nhận việc phát hành/cài đặt do log yếu.	Nhật ký cập nhật	Commit, manifest ký, log; cần log bất biến khi triển khai
I – Information disclosure	Lộ firmware hoặc khóa ký.	Firmware, khóa	AES-GCM; HSM/ACL; không commit khóa riêng
D – Denial of service	Gói lỗi làm thiết bị không boot hoặc cạn tài nguyên.	Bản đang chạy	Giới hạn size, staging, self-test, rollback; TC-05
E – Elevation of privilege	Cài bản giả/cũ để chiếm quyền.	Toàn thiết bị	Chữ ký, sequence, target; TC-02/04

5.3. Ma trận rủi ro 5×5 và ưu tiên

Thang điểm: Khả năng (K) và Tác động (T) từ 1 đến 5; Điểm = $K \times T$. Phân loại 1–4 Thấp, 5–9 Trung bình, 10–16 Cao, 17–25 Nghiêm trọng. Ma trận sau đặt ID rủi ro vào đúng tọa độ ban đầu.

T \ K	1	2	3	4	5
5			R6	R1, R2	
4			R4	R3, R5	
3					
2					
1					

ID	Rủi ro	K	T	Điểm/mức	Ưu tiên
R1	Firmware giả mạo	4	5	20 – Nghiêm trọng	1
R2	Payload bị sửa	4	5	20 – Nghiêm trọng	1
R3	Rollback/phát lại	4	4	16 – Cao	2
R4	Cài sai target	3	4	12 – Cao	3
R5	Bản mới không boot	4	4	16 – Cao	2
R6	Lộ khóa ký	3	5	15 – Cao	1

5.4. Kiểm soát theo rủi ro ưu tiên

Rủi ro	Kiểm soát đầu-cuối	Kiểm soát kênh/vận hành	Còn lại
R1/R2	Ký manifest RSA-PSS; AES-GCM; SHA-256; fail closed.	HTTPS/mTLS, giới hạn size, giám sát kho.	Lộ khóa ký, lỗi parser
R3	Sequence đơn điệu nằm trong manifest đã ký.	Lưu trạng thái nguyên tử; chống mất điện.	Hỏng/rollback bộ đếm
R4	Target/model nằm trong phần đã ký.	Quản lý inventory thiết bị.	Sai mapping sản xuất
R5	Staging, self-test, xác nhận ảnh, rollback.	Phân vùng A/B, watchdog, giới hạn số lần boot.	Lỗi bootloader/flash
R6	Chuỗi tin cậy hỗ trợ rotate/revoke.	HSM, ACL tối thiểu, phê duyệt kép, audit log.	Nội gián/side-channel

HTTPS/mTLS không thay thế chữ ký firmware: nó bảo vệ một đoạn kênh tại thời điểm truyền, còn chữ ký và metadata đã ký bảo vệ đầu-cuối trong suốt vòng đời gói. Tương tự, SHA-256 chỉ phát hiện thay đổi khi giá trị hash được neo trong dữ liệu đã xác thực.

5.5. Rủi ro còn lại và điều kiện xem xét lại

Prototype chấp nhận các rủi ro còn lại: chưa có root of trust phần cứng, HSM, lưu sequence chống mất điện, bootloader thật, benchmark MCU và kiểm thử side-channel. Các rủi ro phải được xem xét lại khi chuyển sang ESP32/MCU thật; thay đổi thuật toán hoặc định dạng manifest; tăng kích thước firmware; thêm nhà phát hành; phát hiện lộ khóa; hoặc triển khai qua Internet. Trước sản xuất cần threat model lại, kiểm thử mất điện/fuzzing, đánh giá độc lập và diễn tập rotate/revoke khóa.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận theo mục tiêu

Mục tiêu	Kết quả	Mức đạt	Minh chứng
MT-01	Xác định tài sản, STRIDE và 6 rủi ro trên ma trận 5×5.	Đạt	Chương 5
MT-02	Có manifest, SHA-256, RSA-PSS, AES-256-GCM và RSA-OAEP.	Đạt trong mô phỏng	src/, configs/, results/
MT-03	Có target, sequence, staging, self-test và rollback.	Đạt trong mô phỏng	TC-04, TC-05
MT-04	Repo có hướng dẫn, code, log, CSV, sơ đồ; chạy lại 5/5 PASS.	Đạt	Commit eda9be5

Kết quả chứng minh nguyên tắc thiết kế chứ không chứng minh một thiết bị thương mại đã an toàn. Đóng góp chính là mô hình nhỏ, minh bạch và có thể chạy lại, trong đó mỗi quyết định ACCEPT/REJECT được nối với một kiểm soát và một rủi ro cụ thể.

6.2. Hạn chế

Hạn chế lớn nhất là chưa triển khai trên MCU thật và chưa tích hợp bootloader/Secure Boot. Khóa demo được tạo trong phần mềm; trạng thái sequence chưa được bảo vệ bằng phần cứng; tập test chỉ có năm ca; chưa đo hiệu năng/tài nguyên và chưa kiểm tra mất điện, lỗi flash, fuzzing hay side-channel. Lịch sử GitHub có nhiều commit cùng ngày 18/07/2026 nên chỉ phản ánh các bước kỹ thuật, không đại diện cho sáu tuần làm việc tách biệt.

6.3. Hướng phát triển

- + Chuyển prototype sang ESP32/ESP-IDF hoặc Wokwi, dùng phân vùng A/B, Secure Boot, flash encryption và eFuse anti-rollback.
- + Đưa khóa ký vào HSM; bổ sung quy trình cấp, xoay vòng, thu hồi và nhật ký phê duyệt.
- + Thêm HTTPS/mTLS, chứng chỉ thiết bị và chính sách phân phối theo nhóm/target.
- + Kiểm thử mất điện, lỗi flash, parser fuzzing; đo thời gian, RAM, kích thước và năng lượng trên MCU.
- + Tích hợp CI để chạy test tự động và lưu artifact/log theo từng commit phát hành.

TÀI LIỆU THAM KHẢO

- [1] B. Moran et al., “A Firmware Update Architecture for Internet of Things Devices,” RFC 9019, IETF, 2021, <https://datatracker.ietf.org/doc/html/rfc9019>. Truy cập 25/07/2026. Dùng cho kiến trúc và vai trò.
- [2] B. Moran et al., “A Manifest Information Model for Firmware Updates in IoT Devices,” RFC 9124, IETF, 2022, <https://datatracker.ietf.org/doc/html/rfc9124>. Truy cập 25/07/2026. Dùng cho manifest và điều kiện.
- [3] NIST, “Platform Firmware Resiliency Guidelines,” SP 800-193, 2018, <https://csrc.nist.gov/pubs/sp/800/193/final>. Truy cập 25/07/2026. Dùng cho protect–detect–recover.
- [4] K. Moriarty et al., “PKCS #1: RSA Cryptography Specifications Version 2.2,” RFC 8017, IETF, 2016, <https://datatracker.ietf.org/doc/html/rfc8017>. Truy cập 25/07/2026. Dùng cho RSA-PSS/OAEP.
- [5] NIST, “Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode,” SP 800-38D, 2007, <https://csrc.nist.gov/pubs/sp/800/38/d/final>. Truy cập 25/07/2026. Dùng cho AES-GCM.
- [6] NIST, “Secure Hash Standard,” FIPS 180-4, <https://csrc.nist.gov/pubs/fips/180-4/upd1/final>. Truy cập 25/07/2026. Dùng cho SHA-256.
- [7] Espressif Systems, “Over The Air Updates (OTA), ESP-IDF v5.4.2,” <https://docs.espressif.com/projects/esp-idf/en/v5.4.2/esp32/api-reference/system/ota.html>. Truy cập 25/07/2026. Dùng cho phân vùng và rollback.
- [8] OWASP, “IoT Security Verification Standard,” <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Truy cập 25/07/2026. Dùng cho yêu cầu cập nhật và bảo vệ khóa.
- [9] Trần Thị Hà Vy, “n20-secure-firmware-update-iot,” commit a8febb243aca96388c1981e141e823b8f397af8b, <https://github.com/hv6z/n20-secure-firmware-update-iot>. Truy cập 25/07/2026. Dùng cho toàn bộ code, cấu hình và minh chứng thực nghiệm.

PHỤ LỤC A. PHẦN A – CHECKLIST VÀ PHIẾU TIẾN ĐỘ

Phụ lục này giữ lại nội dung lịch sử đã điền trong báo cáo Tuần 02. Trạng thái phần trăm là trạng thái tại thời điểm Tuần 02, không phải trạng thái của bản cuối kỳ.

A.1. Checklist nhanh trước khi viết – Tuần 02

Nội dung	Yêu cầu cuối Tuần 02	Trạng thái	Minh chứng
Góp ý lần 1	Đã rà soát mục tiêu, phạm vi, đầu ra và cấu trúc theo đúng mã đề tài 20.	☒ Đạt ☐ Bổ sung	Chương 1 và bảng đối chiếu mục tiêu
Chương 1	Đã viết đủ các mục 1.1-1.6.	☒ Đạt ☐ Bổ sung	Chương 1 của tài liệu này
Chương 2	Đã viết bản nháp khoảng 60-70%, tập trung firmware, OTA, khóa và chuỗi tin cậy.	☒ Đạt ☐ Bổ sung	Các mục 2.1-2.6
Tài liệu	Có 5 nguồn chính và các nguồn mở rộng trong thư mục references.	☒ Đạt ☐ Bổ sung	Bảng nguồn tại mục 2.4
Repo	Có README, mã nguồn, cấu hình, dữ liệu giả lập và thư mục kết quả.	☒ Đạt ☐ Bổ sung	Repo GitHub/README.md
Chuẩn bị Buổi 03	Có dàn ý Chương 3, sơ đồ OTA an toàn và kế hoạch kiểm thử.	☒ Đạt ☐ Bổ sung	Chương 3 và update_so_do_hinh_anh/

A.2. Góp ý và cách xử lý – Tuần 02

Góp ý	Cách đã xử lý	Vị trí trong bản thảo	Trạng thái
Chưa có góp ý chi tiết bằng văn bản từ giảng viên.	Tự rà soát theo yêu cầu Tuần 02 và mã đề tài 20.	Toàn bộ Chương 1-2	Chờ giảng viên bổ sung
Nội dung tự rà soát: cần	Bổ sung ca <code>'tampered_manifest_signature'</code> và	Repo: src/ và results/	Đã xử lý

Góp ý	Cách đã xử lý	Vị trí trong bản thảo	Trạng thái
chứng minh chữ ký manifest.	manifest có chữ ký.		
Nội dung tự rà soát: sơ đồ luồng cần rõ biên tin cậy.	Số hóa quy trình phát hành-máy chủ-thiết bị và các bước reject.	update_so_do_hinh_anh/	Đã xử lý
Cần bổ sung góp ý từ giảng viên			Chờ bổ sung

A.3. Minh chứng đã khai báo – Tuần 02

ID	Loại	Tên file/link/commit	Nội dung chứng minh	Ngày
MC-01	Repo/README	https://github.com/hv6z/n20-secure-firmware-update-iot	Cấu trúc, cách chạy, nguồn và giới hạn an toàn	18/07/2026
MC-02	Mã nguồn	src/code_demo.py	Tạo gói, xác minh chữ ký, giải mã, anti-rollback và	18/07/2026

ID	Loại	Tên file/link/commit	Nội dung chứng minh	Ngày
			self-test	
MC-03	Log/Bảng	results/logs/secure_update_demo.log results/test_matrix.csv	Năm ca kiểm thử đều đạt kỳ vọng	18/07/2026
MC-04	Manifest	results/signed_manifest_v2.json	Manifest và chữ ký dùng để kiểm tra nguồn gốc	18/07/2026
MC-05	Sơ đồ	update_so_do_hinh_anh/so_do_ota_an_toan.png	Luồng OTA an toàn và các điểm từ chối	18/07/2026

A.4. Thông tin chung của phiếu tiến độ

Mã SV	231A010297	Họ và tên	Trần Thị Hà Vy
Lớp	253INT441001	Tuần báo cáo	Tuần 02
Mã đề tài	20	Tên đề tài	Cập nhật firmware an toàn cho thiết bị IoT
Link GitHub/repo	https://github.com/hv6z/n20-secure-firmware-update-iot	Link minh chứng	Repo GitHub và thư mục results/

Mã SV	231A010297	Họ và tên	Trần Thị Hà Vy
Ngày cập nhật	18/07/2026	Mức tự đánh giá	☒ Đúng tiến độ ☐ Cần hỗ trợ ☐ Nguy cơ chậm
Email/SĐT liên hệ	havytran1111@gmail.com	Nhóm/cá nhân	☒ Cá nhân ☐ Nhóm

A.5. Checklist tiến độ Tuần 02

STT	Nội dung cần hoàn thành	Trạng thái	Ghi chú/minh chứng
1	Đã tạo repo GitHub/thư mục làm việc và đặt tên đúng đề tài.	☒ Xong ☐ Đang làm ☐ Chưa làm	Repo đúng tên, có README và cấu trúc src/configs/data/results/report.
2	Đã viết đề cương 1-2 trang: lý do chọn đề tài, mục tiêu, phạm vi, sản phẩm dự kiến.	☒ Xong ☐ Đang làm ☐ Chưa làm	Chương 1 hoàn chỉnh; đã xác định lý do, vấn đề, mục tiêu, phạm vi và đầu ra.
3	Đã thu thập tối thiểu 5 tài liệu tham khảo, trong đó có ít nhất 1 repo/tool GitHub liên quan.	☒ Xong ☐ Đang làm ☐ Chưa làm	Có ít nhất 5 nguồn chính: ESP-IDF, OWASP ISVS, FSTM, IETF SUIT và IoTGoat.
4	Đã xác định công cụ hoặc phương pháp chính sẽ dùng: lab, checklist, STRIDE, OWASP, demo, code hoặc phân tích case study.	☒ Xong ☐ Đang làm ☐ Chưa làm	Phương pháp: nghiên cứu tài liệu, mô hình luồng, demo Python, ca thử dương/âm và đánh giá rủi ro.
5	Đã có kế hoạch Tuần 03 rõ ràng: chạy thử, thu log/ảnh minh chứng, hoàn thiện bảng rủi ro hoặc demo.	☒ Xong ☐ Đang làm ☐ Chưa làm	Đã có dàn ý Chương 3, sơ đồ OTA và kế hoạch bổ sung test plan/ma trận rủi ro.

A.6. Nội dung đã thực hiện trong tuần

ST T	Công việc	Kết quả hiện tại	Minh chứng/link/file	Tỷ lệ hoàn thành
1	Viết Chương 1	Hoàn thành các mục 1.1-1.6 và bảng đối chiếu mục tiêu.	Báo cáo Tuần 02 - Chương 1	100%
2	Viết bản nháp Chương 2	Hoàn thành khoảng 60-70% về kiến trúc, mật mã, firmware/OT A và nguồn liên quan.	Báo cáo Tuần 02 - Chương 2	70%
3	Thu thập và phân loại nguồn	Có 5 nguồn chính, ghi rõ URL, phiên bản, phần sử dụng và ngày truy cập.	Bảng nguồn mục 2.4; references/link_nguon.md	100%
4	Xây dựng sơ đồ và threat model	Có kiến trúc ba vùng, biên tin cậy và luồng xác minh trước khi cài.	update_so_do_hinh_anh/so_do_ota_an_toan.png	80%
5	Chuẩn bị prototype và minh chứng	Có mã Python, manifest, log và ma trận 5 ca kiểm thử để phát triển ở các tuần sau.	src/code_demo.py; results/	100%

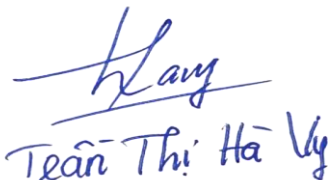
A.7. Khó khăn/rủi ro đang gặp

Vấn đề	Ảnh hưởng tới tiến độ	Hỗ trợ cần từ GV/bạn học
Demo hiện chỉ chạy bằng Python, chưa có ESP32/bootloader/flash A-B thật.	Chưa thể kết luận về RAM, thời gian xác minh và khả năng chịu mất điện trên phần cứng.	Nhờ giảng viên xác nhận phạm vi mô phỏng hoặc yêu cầu bổ sung phần cứng.
Quản lý vòng đời khóa chưa được triển khai bằng HSM/secure element.	Chưa chứng minh rotation, revocation và bảo vệ khóa ở mức sản xuất.	Xin góp ý mức độ cần trình bày trong Chương 5.
Chưa có góp ý chi tiết cho bản Tuần 02.	Có thể phải điều chỉnh bố cục hoặc độ sâu Chương 2 sau khi nhận xét.	Nhờ giảng viên đánh dấu các mục cần ưu tiên sửa.

A.8. Kế hoạch Tuần 03

Công việc Tuần 03	Sản phẩm dự kiến	Thời hạn	Ghi chú
Hoàn thiện Chương 2 và chuẩn hóa trích dẫn	Chương 2 hoàn chỉnh và bảng nguồn đã rà soát	22/07/2026	Bổ sung theo góp ý
Viết Chương 3 - phương pháp và thiết kế	Sơ đồ kiến trúc, threat model và mô tả quy trình	24/07/2026	Dùng dữ liệu giả lập
Hoàn thiện test plan và tiêu chí đánh giá	Bảng ca thử chấp nhận/từ chối và tiêu chí PASS/FAIL	25/07/2026	Gắn với MT-01 đến MT-04
Cập nhật repo và minh chứng	Commit, README, ảnh/log và bảng rủi ro bản đầu	25/07/2026	a8febb243aca96388c1981e141e823b8f397af8b

A.9. Tự đánh giá của sinh viên

Tiến độ tự đánh giá	☐ 0-25% ☒ 26-50% ☐ 51-75% ☐ 76-100%
Mức độ hiểu đề tài	☐ Chưa rõ ☐ Cơ bản ☒ Khá rõ ☐ Rất rõ
Cam kết tuần tới	Hoàn thành Chương 2 và Chương 3 đúng kế hoạch; cập nhật repo, test plan và minh chứng trước 25/07/2026.
Chữ ký/tên sinh viên	 Trần Thị Hà Vy

PHỤ LỤC B. REPOSITORY, COMMIT VÀ GÓI NỘP

Repository: <https://github.com/hv6z/n20-secure-firmware-update-iot>

Commit main kiểm tra lần cuối: a8febb243aca96388c1981e141e823b8f397af8b (27/07/2026).

Commit	Ngày	Nội dung
a8febb243aca96388c1981e141e823b8f397af8b	27/07/2026	Commit main duy nhất dùng để đối chiếu toàn bộ nội dung, mã nguồn và minh chứng trong báo cáo.

PHỤ LỤC C. CHECKLIST TRƯỚC KHI IN VÀ NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Đúng tên file MSSV_HoTen_DeTai20_TieuLuan_CuoiKy (.docx và .pdf).	☒ Đạt
2	Một file có Chương 1–6, tài liệu tham khảo và phụ lục tiến độ.	☒ Đạt
3	Đã xóa hướng dẫn mẫu, phụ lục 50 đề tài và chỗ giữ chỗ.	☒ Đạt
4	Mục lục tự động, tiêu đề dùng Heading 1/2.	☒ Đạt
5	Hình/bảng có số, tên, nguồn và được phân tích.	☒ Đạt
6	Kết quả Chương 4 khớp log/CSV tại commit đã khai.	☒ Đạt
7	Có ≥ 5 nguồn, URL sạch, ngày truy cập và phần sử dụng.	☒ Đạt
8	Không có secret, token, mật khẩu hoặc khóa riêng triển khai.	☒ Đạt
9	Đã ghi rõ mô phỏng local, không tuyên bố chạy phần cứng thật.	☒ Đạt
10	Cần cập nhật README và tải DOCX/PDF cuối lên GitHub trước nộp.	☐ Sinh viên thực hiện
11	Mở PDF kiểm tra lần cuối và ký tên bản in.	☐ Sinh viên thực hiện

PHỤ LỤC D. CÂU HỎI CHUẨN BỊ BẢO VỆ

Câu hỏi	Trả lời ngắn
Vì sao không chỉ dùng SHA-256?	Hash phát hiện thay đổi nhưng không xác thực nguồn nếu kẻ tấn công có thể thay cả firmware và hash; hash phải nằm trong manifest đã ký.
HTTPS có thay thế chữ ký firmware không?	Không. HTTPS bảo vệ kênh; chữ ký bảo vệ đầu-cuối và còn kiểm tra được sau khi gói qua cache hoặc máy chủ trung gian.
Vì sao chữ ký hợp lệ vẫn cần sequence?	Một firmware cũ có thể vẫn mang chữ ký hợp lệ; sequence lưu trên thiết bị ngăn rollback/phát lại.
Vì sao cần AES-GCM và nonce duy nhất?	AES-GCM vừa bí mật vừa toàn vẹn payload; tái sử dụng nonce với cùng khóa có thể phá vỡ bảo mật.
Vì sao cần staging và self-test?	Chữ ký chỉ chứng minh nguồn và nội dung không bị sửa, không chứng minh firmware chạy đúng; staging cho phép rollback.
Điểm yếu lớn nhất của mô hình?	Chưa có phần cứng root of trust, bootloader, lưu trạng thái chống mất điện và phép đo tài nguyên trên MCU thật.